

정보화 용역사업 단계별 확인 사항

1. 용역사업 입찰 및 계약시 확인 사항

구분	보안대책	양호	미흡	비고
용역사업 착수 및 입찰	중요 정보화 사업의 경우 사업 착수단계부터 사업계획 전반에 대해 적정 등급의 비밀 또는 대외비 분류			
	입찰공고 이전에 보안관리가 필요한 자료·장비에 대해 관련 법규에 따라 등급을 분류하고 필요한 요구사항을 마련			
	입찰공고시 누출금지 대상정보, 부정당업자 제재조치, 기밀 유지 의무 및 위반 불이익 등에 대해 공지			
	제안서 평가요소에 보안관리 계획에 대한 평가항목 및 배점 기준 마련			
	입찰제안서에 제시한 용역사업 전반에 대한 보안관리 수행 계획의 타당성 검토			
	웹호스팅 등 정보시스템 위탁 운영시 정보보호 시스템 구비 및 보안관리 기능 여부 검토			
용역사업 계약	발주기관의 요구사항이 과업지시서·계약서에 명시될 수 있도록 중요 항목(보안조치·누출금지 대상정보·제재조치)을 기술			
	용역업체가 사업에 대한 하도급 계약을 체결할 경우 원래 사업계약 수준의 비밀유지 조항 포함			
	대외보안 필요시 비밀유지 계약서에 비밀정보 범위, 보안 준수사항, 위반시 손해배상 책임, 지적 재산권 문제, 자료 반환 등 중요항목 명시			

2. 용역사업 수행시 점검 및 확인 사항

구분	보 안 대 책	양호	미흡	비고
인원 및 물리적 보안관리	용역사업 참여인원의 신원확인 실시 여부			
	용역사업 참여인원 보안서약서 징구 여부			
	용역사업 수행 전 참여인원에 대해 '비밀유지 의무 준수' 및 '누출금지 대상정보' 위반시 처벌내용 등에 대한 보안교육 실시			
	용역사업 수행 중 참여인원에 대한 보안점검을 실시하여 '누출 금지 대상정보'의 누출여부 확인			
	CCTV·잠금장치 등 비인가 출입통제 대책이 마련된 사무실 사용 여부			
	CCTV 등 통제장치의 관리상태(작동여부, 사각지대 보완 등) 및 기록 확인			
	용역사업 참여인원의 신상변동(휴가 및 해외여행 포함)에 대한 대책 마련			

구분	보안대책	양호	미흡	비고
내·외부 전산망 접근 시 보안관리	용역업체 정보통신망은 방화벽 등을 활용하여 발주기관 업무망 및 기관 인터넷망과 분리하고 업무상 필요한 서버에만 제한적 접근 허용			
	용역업체 PC의 인터넷 연결 차단 여부 및 인터넷 접속허용 PC에 대한 보안조치			
	비인가무선 AP(무선공유기 등) 설정을 금지하고 휴대형 무선 모뎀(WiFi 등) 반입 통제			
	스마트폰·휴대폰을 무선 모뎀으로 활용하지 못하도록 통제수단 강구(PC에 비인가 통신기기 접속차단 S/W 설치, 스마트폰 접속 단자 봉인조치 등)			
	노트북PC 반입 시 무선통신 기능 불능화 조치 (드라이버 삭제 등) 시행			
	기관 외부에서 기관 내부의 시스템 개발PC 및 기관 시스템에 원격접속 금지			
	용역업체 직원의 계정은 하나의 그룹으로 등록하고 계정별로 정보시스템 접근권한을 부여하되 기관 내부분서 접근 금지			
	용역업체 직원의 'root' 계정 등 시스템에 중대한 영향을 끼칠 수 있는 계정에 대한 접근 불허			
	계정별로 부여된 권한은 불필요시 곧바로 해지하거나 계정 폐기			
	용역업체 직원의 작업내용 확인을 위해 작업이력 로깅기능 구축			
	용역사업 책임자는 서버 및 장비 운영자로 하여금 내부서버 및 네트워크 장비에 대한 접근기록을 매일 확인하여 이상유무 보고			

구분	보안대책	양호	미흡	비고
자료에 대한 보안관리	계약서 등에 명시한 누출금지 대상정보를 용역업체에 제공할 경우, 자료 인계인수대장을 작성하고, 인계자·인수자가 자필로 서명한 후 제공			
	비밀유지 계약서에 비밀정보의 범위, 보안 준수사항, 위반 시 손해배상 책임, 지적재산권 문제, 자료의 반환 등 중요항목 명시			
	용역사업 관련 자료는 웹하드, P2P, 웹오피스, 클라우드 서비스 등 인터넷 자료공유 사이트 및 개인 메일함에 저장 금지			
	기관의 파일서버에 용역사업 관련자료 및 모든 산출물을 저장하거나 용역사업 책임자가 지정한 PC(인터넷 연결 차단)에 저장 및 관리			
	발주기관이 제공한 사무실에서 용역사업을 수행할 경우, 기관이 제공한 비공개 자료는 매일 퇴근시 반납			
	용역사업 수행으로 생산되는 산출물 및 기록은 비인가자에게 제공, 대여, 열람 금지			
	비밀번호는 정보보안담당관이 별도로 기록·관리하고 수시로 해당 계정에 접속하여 저장된 자료와 작업이력 확인			

3. 용역사업 완료시 점검 및 확인 사항

구분	보안대책	양호	미흡	비고
용역사업 완료	사업 완료 후 생산되는 최종 산출물 중 대외보안이 요구되는 자료에 대해 대외비 이상으로 작성·관리하고 불필요한 자료는 삭제 또는 폐기			
	용역업체에 제공한 용역사업과 관련된 제반자료는 전량 회수하여 자료 인계인수대장을 작성하고, 용역업체가 별도의 복사본 보관 금지			
	용역업체에 복사본 등 용역사업과 관련된 자료를 일체 보유하고 있지 않다는 용역업체 대표 명의의 보안확약서를 징구			
	용역업체 소유의 전자기록 저장매체는 인증을 득한 삭제 S/W로 완전 삭제, 정보보안담당자로부터 승인 후 반출			
	용역업체에서 설정한 정보시스템의 계정과 비밀번호 변경조치			

4. 원격지 개발시 점검 및 확인 사항

보안대책	양호	미흡	비고
1. 발주기관과 용역업체가 협의하여 원격지 개발 장소 사전 선정			
2. 용역업체 작업장소에 대한 관리·물리·기술적 보안대책을 수립·시행			
3. 용역업체에 대해 보안대책을 점검·시행하고 미비점에 대한 시정조치를 요구			
4. 용역업체의 개발망은 용역업체의 내부망·인터넷망 등과 분리하여 독립망으로 운영			
5. 발주기관 내에서 개발용역을 수행하더라도 개발용 서버가 민간 클라우드 컴퓨팅 서비스를 이용하면 원격지 개발로 간주 하고 보안 대책을 수립·시행			
6. 개발PC는 개발업무 외 사용 금지 등의 보안대책을 수립·시행			
7. 서버 등 정보시스템은 관리자와 일반 사용자 계정을 분리하는 등의 보안대책을 수립·시행			
8. 개발 과정에서 발주기관의 실제 운용데이터 사용을 금지하며, 필요시 발주기관과 협의하여 중요자료를 제외한 테스트용 데이터를 활용			
9. 수행내역 및 정보시스템 접속 이력 등 로그를 저장하고 1년 이상 유지			

5. 원격지에서 온라인 개발시 점검 및 확인 사항

보안 대책	양호	미흡	비고
1. 발주기관과 용역업체가 협의하여 온라인 개발을 위한 원격지 장소 사전 선정			
2. 온라인 개발 통제시스템 상시 접속 유지 금지			
3. 개발망은 발주기관의 업무망 및 기관 인터넷망과 분리			
4. 용역 종료 후에는 개발 관련 정보시스템의 원격접속 포트를 비활성화하고 임시계정과 접근권한을 제거			
5. 용역업체와 발주기관의 통신 구간에 VPN 등 암호화 적용			
6. 개발PC는 개발업무 외 사용 금지 등의 보안대책을 수립·시행			
7. 서버 등 정보시스템은 관리자와 일반 사용자 계정을 분리하는 등의 보안대책을 수립·시행			
8. 개발실 전산망 보호를 위해 IDS·방화벽·접근통제 등 정보보호시스템 설치·운영			
9. 수행내역 및 정보시스템 접속 이력 등 로그를 저장하고 1년 이상 유지			

5. 원격지에서 온라인 유지관리시 점검 및 확인 사항

항 목	양호	미흡	비고
1. 발주기관과 용역업체가 협의하여 온라인 유지보수를 위한 원격지 장소 사전 선정			
2. 발주기관은 온라인 유지보수 대상 정보시스템 사전 검토·선정			
3. 온라인 유지보수를 위한 접속 경로 상시(24시간) 개방 금지			
4. 보안·네트워크 장비에 원격 접속 금지			
5. 유지보수 전용단말은 목적 외 사용 금지 등의 보안대책을 수립·시행			
6. 발주기관의 정보통신망 또는 정보시스템에 허가 없이 접속하거나 무단으로 정보를 수집하는 행위를 금지			
7. 비인가 프로그램 설치 또는 취약점을 고의로 생성 또는 방치하는 행위 등을 금지			
8. 온라인 유지보수 통제시스템을 경유하지 않는 유지보수 방법은 금지			
9. 수행내역 및 정보시스템 접속 이력 등 로그를 저장하고 1년 이상 유지			